INFORME TÉCNICO DE IMPLEMENTACIÓN

Detección y prevención de fuga de información

Agente Windows, controles de salida y clasificación híbrida con Groq

Objeto	Contenido
Sistema	Laboratorio administrado de endpoint y red
Escenarios	Doce casos de uso de transferencia o exfiltración controlada
Evaluación	Detección, prevención, errores y evidencia de destino
Versión	3.0.0 - octubre de 2026

El documento distingue los componentes implementados de su despliegue y validación. Una decisión de bloqueo, una alerta y una restricción ejecutada representan evidencias diferentes.

Alcance académico: datos ficticios, receptores independientes y configuración reproducible. La exactitud del modelo con una clave real se evalúa por separado; no se atribuyen resultados de Groq a pruebas simuladas.

1. Propósito y modelo de control

El sistema clasifica información sensible y decide si una transferencia debe permitirse, alertarse o retenerse. La protección combina un agente local con puntos de control de red. La clasificación de privacidad no equivale a detección de archivos maliciosos.

Actores y responsabilidades

Actor	Responsabilidad
Usuario de prueba	Crea documentos ficticios y ejecuta las transferencias.
Administrador	Configura carpetas, destinos, políticas y despliegue.
Evaluador	Fija etiquetas de referencia, comprueba receptores y calcula errores.
Conectores	Retienen las acciones soportadas y reportan su resultado.

Estados que deben distinguirse

Estado	Significado verificable
PERMITIDO	El canal admite la operación; comprobar aceptación y hash.
DETECTADO	Se reconoce un indicador en modo auditoría y se permite.
ALERTA	Existe indicador o actividad que exige revisión; puede permitirse.
BLOQUEADO	La política exige retener. Confirmar la cancelación o ausencia en destino.
NO INSPECCIONABLE	No se pudo examinar todo el contenido. La restricción no demuestra sensibilidad.

Las copias nativas observadas después de escritura generan alertas. La prevención selectiva se acredita únicamente en operaciones mediadas o en controles de red que actúan antes de reenviar. USBWrite restringe el canal USB completo.

2. Arquitectura de red

DLP-Control-WSL aloja los servicios Linux sobre WSL2. Windows ejecuta el agente y accede a sus puertos locales. La alternativa VirtualBox se conserva apagada; otras VM necesitan una interfaz privada de laboratorio configurada explícitamente.

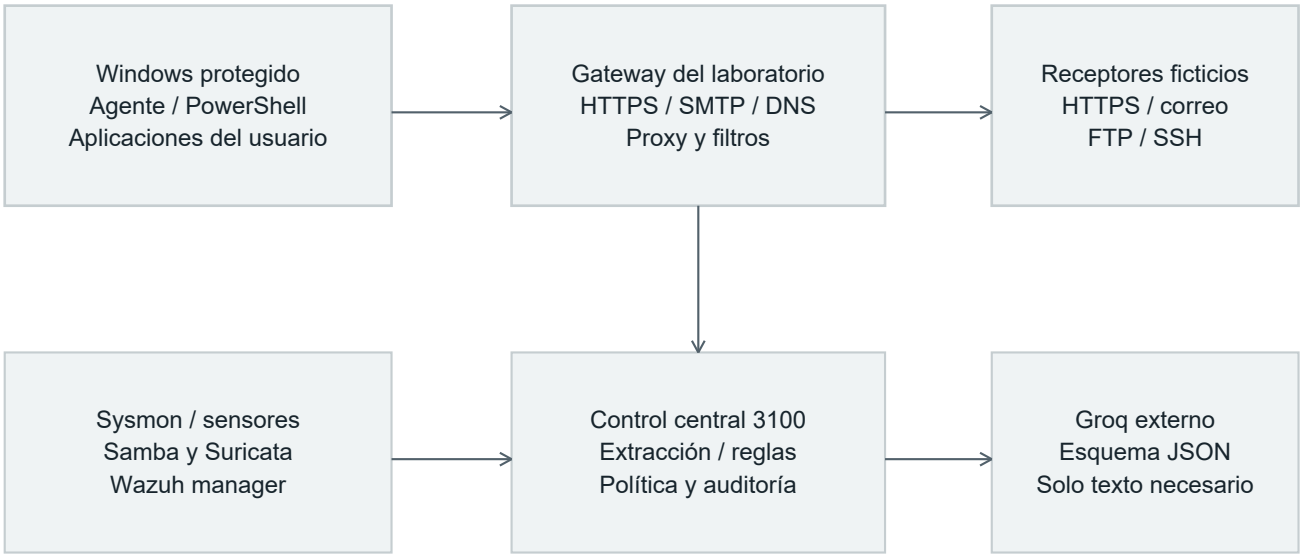


Figura 1. Topología lógica y rutas de decisión. Las flechas de red no representan inspección de todo protocolo cifrado.

Interfaz	Servicios
Acceso desde Windows	3100 central; 8080 proxy; 2525 SMTP; 1514/1515 Wazuh; 5300/UDP DNS de prueba. VirtualBox añade SSH en 2222.
Docker interna	172.30.50.0/24: cliente, receptores y sensores. El cliente restringe su salida al gateway.
Red de administración	Publicación de servicios autorizados; separada del namespace restringido del cliente.

3. Clasificación y decisión

Cada conector retiene la acción mientras se verifica destino, formato, extracción y política. El motor trabaja sobre una instantánea; el agente comprueba el hash devuelto por el control para evitar confiar en un inventario antiguo.



Reglas y modos

Por defecto: 0 puntos permite, 1-2 alerta y permite, 3 o más bloquea en enforce. En audit se detecta sin impedir; en alert se avisa y permite. Los puntos son reglas de decisión, no probabilidades.

Formato desconocido, extracción parcial, cifrado o fallo semántico se retienen en enforce. Deben contabilizarse por separado de una detección correcta de sensibilidad.

4. Integración con Groq

El modelo interpreta contenido privado que no contiene etiquetas ni patrones exactos. Recibe texto extraído, delimitado como entrada no confiable. No tiene herramientas, permisos sobre Windows ni instrucciones de ejecutar acciones.

Contrato	Implementación
Clases	PUBLICO, INTERNO, CONFIDENCIAL, RESTRINGIDO y NO_DETERMINADO.
Respuesta	JSON con propiedades y valores permitidos; validación adicional en el servidor.
Presupuesto	Hasta 48 000 caracteres, fragmentos de 6 000 y solapamiento de 256; máximo nueve fragmentos.
Disponibilidad	Dos consultas concurrentes, límite por llamada y 45 s por clasificación. Caché por hash durante 30 minutos.
Fallo	Clave ausente, cuota, error o ambigüedad retienen la salida en enforce. No se convierte el documento en público.
Privacidad	Los bloqueos locales fuertes evitan una consulta externa. No se persiste el texto del modelo en auditoría.

Activación al final

Configurar GROQ_API_KEY en el .env local. Ejecutar groq:check con un ejemplo ficticio, sincronizar la VM y luego evaluate:hybrid. La clave no se publica ni se introduce en la consola web.

Las pruebas automatizadas del contrato usan respuestas simuladas. Sin una clave y consultas reales no hay una medición de exactitud de Groq. Los límites y la disponibilidad de la cuenta gratuita deben comprobarse con el proveedor.

5. Casos de uso 01-06

Caso y acción	Control	Criterio y límite
CU-01 USB	Transferencia mediada y política Windows.	Prueba física pendiente del equipo; política nativa restringe todo el canal.
CU-02 Ruta no autorizada	Sensor de destino, hash y full_audit.	Alerta posterior; lectura Samba no prueba destino final.
CU-03 Adjunto sensible	Postfix y filtro MIME con extracción.	Receptor SMTP aislado; formatos admitidos.
CU-04 Cuerpo del correo	Decodificación MIME, asunto y texto.	250 permitido, 550 restringido, 451 si falla el motor.
CU-05 Subida HTTPS	Proxy TLS y política central.	Requiere CA y rutas forzadas; verificar receptor.
CU-06 Texto público web	Inspección de formularios y parámetros.	Protocolos no inspeccionables se retienen.

Escenario de prueba

Ejecutar un documento público y otro privado con el mismo canal y destino. Registrar la verdad de referencia antes de probar, la clasificación, el modo activo, la decisión y el efecto. Añadir un control negativo que confirme que el receptor funciona sin ese control.

Una restricción por destino, formato desconocido o falta de clave no se cuenta como reconocimiento de sensibilidad. Debe informarse su causa y el posible bloqueo de un documento público.

6. Casos de uso 07-12

Caso y acción	Control	Criterio y límite
CU-07 rclone	Proxy y restricción de rutas.	WebDAV HTTPS probado; otros backends por separado.
CU-08 SCP / SFTP	Firewall por canal y destino.	No descifra el contenido SSH.
CU-09 FTP claro	Suricata IDS y Wazuh.	Detecta flujo visible; prevención por firewall, no por IDS pasivo.
CU-10 Túnel DNS	Resolver, dnsmasq y restricciones.	Anomalía no demuestra que los datos sean confidenciales.
CU-11 Archivo cifrado	Política de contenido no inspeccionable.	Retención conservadora sin descifrar.
CU-12 Evasión por formato	Firma real, base64 y rechazo parcial.	Sin OCR ni reconstrucción arbitraria de fragmentos.

Escenario de prueba

Ejecutar un documento público y otro privado con el mismo canal y destino. Registrar la verdad de referencia antes de probar, la clasificación, el modo activo, la decisión y el efecto. Añadir un control negativo que confirme que el receptor funciona sin ese control.

Una restricción por destino, formato desconocido o falta de clave no se cuenta como reconocimiento de sensibilidad. Debe informarse su causa y el posible bloqueo de un documento público.

7. Verificación y errores

Batería	Estado y lectura correcta
Pruebas funcionales	40 pruebas Node y 5 pruebas Python; verificar nuevamente con los comandos del repositorio.
HTTPS / SMTP / rclone	16 escenarios de red reales. Groq en vivo: no.
Servicios Linux	17 comprobaciones superadas antes de terminar. Batería completa: sí. Modo restaurado: sí. Entorno: WSL2.
Windows nativo	Impresión pública real a PDF y retención previa del sensible verificadas. USB físico, firewall Apply y enrolamiento de otro equipo requieren prueba en su VM.
Groq real	Pendiente de clave y evaluación independiente. No se atribuyen resultados reales a respuestas simuladas.

Diseño de evaluación

Construir dos matrices de confusión: reconocimiento de sensibilidad y prevención de salida. Precisión = TP / (TP + FP); recall = TP / (TP + FN). Informar además latencia, errores, no inspeccionables y bloqueos públicos.

Las muestras actuales son de desarrollo. Repetir un documento en varios canales aumenta las operaciones, pero no crea documentos independientes. La evaluación semántica debe incluir casos nuevos, ambigüedad, formatos distintos e instrucciones incrustadas.

Fuentes de evidencia: auditoría encadenada; recibos de los conectores; hashes/bytes en receptor independiente; alertas Wazuh; firmas Suricata; eventos nativos. Las fuentes y sus límites deben acompañar cada conclusión.

8. Instalación, operación y límites

Despliegue reproducible

Node.js 24+ para el agente. Docker Linux y Compose v2 para el sistema completo. La alternativa VirtualBox provisiona Ubuntu automáticamente. Python 3.12+ permite las pruebas y el laboratorio local reducido. setup genera credenciales y muestras sin imprimir claves.

Inicio preparado: wsl:start, wsl:sync, wsl:ca y agent. La consola usa el token administrativo local. wsl:verify prueba los servicios con reglas y restaura el modo configurado. Para otra PC exportar una configuración de endpoint sin la clave Groq ni el token de administración.

Controles administrativos

Managed-Egress y System-Controls comienzan en Plan. Apply se reserva al Windows aislado, requiere administrador y conserva respaldo. Restore retira los cambios propios. Instalar Sysmon/Wazuh y configurar DNS/proxy/CA son pasos de despliegue del equipo protegido; no se realizaron silenciosamente en la PC principal.

Límites de la implementación

No incorpora driver de kernel, OCR, descifrado ni protección frente a administradores. Las copias nativas son observadas después de escritura. Las aplicaciones con certificate pinning pueden no aceptar inspección TLS. La cobertura depende de los conectores y rutas efectivamente desplegados.

Los PDF de portal y endpoint v2 se conservan como históricos; este informe describe la ampliación administrada. La guía y el código fuente incluyen las rutas exactas y los comandos reproducibles.

9. Referencias técnicas

Groq. Structured outputs.
https://console.groq.com/docs/structured-outputs

Groq. Your data.
https://console.groq.com/docs/your-data

mitmproxy. Event hooks.
https://docs.mitmproxy.org/stable/api/events.html

Postfix. Before-queue content filter.
https://www.postfix.org/SMTPD_PROXY_README.html

Wazuh. Docker deployment.
https://documentation.wazuh.com/current/deployment-options/docker/wazuh-container.html

Microsoft. Sysmon.
https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon

Debian. Suricata packages.
https://packages.debian.org/trixie/suricata

Trazabilidad del proyecto

Repositorio: github.com/Brando-01/DLP. Arquitectura ampliada: docs/ARQUITECTURA_ADMINISTRADA.md. Resultados: output/evaluacion/. Generador reproducible de este documento: docs/generar_informe_administrado.py.